

-
File No.: PS/00413/2022

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. A.A.A. (hereinafter, the complainant), on 14/05/2021, filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against METROPOLITAN SPAIN, S.L., with NIF B62936737 (hereinafter, the respondent).

The reasons on which the complaint is based are as follows:

The complainant is a member of the METROPOLITAN CLUB gym, located at c/ Cisneros 67 in Santander. She joined this center in September 2020, and until 6/05/2021, access was granted via a wristband and an identification card at the reception computer. Since the aforementioned date, users have been required to access the facilities using a fingerprint. She has refused to provide her fingerprint data, understanding that this is an excessive request for biometric data, and has been informed that they will terminate her membership, with no alternative provided.

She provides a copy of the complaint form submitted to Consumer Affairs on May 6, 2021, a copy to be sent by the complainant to the General Directorate indicated on the form within 10 days, without any record of its submission.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of 5/12, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of 1/10, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on 7/06/2021, as evidenced by the acknowledgment of receipt in the file.

No response has been received to this forwarding letter.

THIRD: On 14/08/2021, in accordance with and for the purposes of Article 65.5 of the LOPDGDD, the complaint was considered admitted for processing.

FOURTH: The General Subdirector for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

As a result of the information request made by the inspection to METROPOLITAN SPAIN, S.L., on 21/03/2022, METROPOLITAN SPAIN, S.L. submitted the following information and statements to this Agency:

1. They indicate that they provide information about METROPOLITAN as it was requested, but they also include other information from LLEFISA SL, which is the owner of CLUB AQUA FLORANES where the respondent was a member from 2/09/2020 to 1/06/2021. They state that "biometrics were installed in that Club in February 2021 as the only means of access along with the wristband" (point 23 of their response).
2. METROPOLITAN specifies that, although the processing of health data is generally prohibited, Article 9.2.a) of the GDPR indicates the exception, limiting itself to citing it. They add that: "the legal basis (Article 6 of the GDPR) on which these personal data processing activities are based, in this case, is the consent of the interested party to provide their fingerprint to establish the biometric pattern and by signing the membership regulations where this processing is informed."
3. They provide a COPY OF THE WRITTEN DOCUMENT FROM "METROPOLITAN SPORT CLUB & SPA" (hereinafter, the contract), with a reference in the right margin to LLEFISA SL. It contains the personal data of the complainant. Thus, in the section "object of the contract" "date of registration" 2/09/2020.

It is noted that the holder of the bank account listed authorizes LLEFISA to charge the payment of the contracted fee.

It also states:

- "DATA PROTECTION: In accordance with current data protection regulations, you may exercise your rights of access, rectification, limitation, deletion, portability, and opposition to the processing of your personal data, as well as the revocation of the consent granted for their processing, by directing your request to LLEFISA, S.L., at C/ Cisneros nº 67, 39007 Santander or to the email dpo@clubmetropolitan.net. "You may file a complaint with the AEPD."

- It informs of the "METROPOLITAN AQUA REGULATIONS," which begins with:

"1. Through this document, LLEFISA, S.L. (METROPOLITAN AQUA FLORANES) will provide the services for the use of its facilities and sports machinery with access to the center located at C/ Cisneros nº 67, 39007 Santander."

- In point 5, "information and operation of the Club": "All members have a personal and non-transferable wristband. To access the facilities, it is necessary to use a biometric system along with the access wristband."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/50

- It refers to the status of a member of METROPOLITAN, and mentions other centers and facilities of METROPOLITAN in other cities where access may be granted.

4. It also provides a document signed by the claimant regarding: "AUTHORIZATION FOR THE PROCESSING OF PERSONAL DATA" (hereinafter, data protection clause) which states that:

"We inform you that LLEFISA, SL complies with all the requirements established in the regulations on the Protection of Personal Data, RGPD 2016/679 (EU) and that all data under our responsibility is being processed in accordance with legal requirements, maintaining the necessary security measures that guarantee their confidentiality.

The personal data you have provided, including your name and surname, ID number, postal and/or electronic address, as well as your credit card number, will be processed by LLEFISA SL, with CIF B60422417 at c/ Cisneros nº 67, 39007-SANTANDER for the purpose of managing your application for membership at the gym and related purposes such as managing and collecting fees, access to the facilities, participation in events and master classes, etc.

In order to protect the safety of individuals accessing the center and their belongings, as well as the facilities themselves, METROPOLITAN opts for an access system using biometric registration (encrypted hash code) and a personal bracelet that will complement the biometric use... Such biometric data will not be processed in any case by METROPOLITAN.

Biometrics and the bracelet must work together to access the center, and they will not operate independently. These are necessary service conditions for the proper functioning of the center, and if they are not accepted, we cannot provide the service to the member. In accordance with current data protection regulations, you may exercise your rights of access, rectification, limitation, deletion, portability, and opposition to the processing of your personal data, as well as the revocation of the consent given for their processing, by directing your request to LLEFISA SL, c/ Cisneros nº 67, 39007-Santander."

5. METROPOLITAN states that "The purpose of the processing is the unequivocal and non-transferable access of the user to the gym facilities."

6. Regarding the operation of the system and the access process, METROPOLITAN states:

- The user's record is stored in the PROVIS software, the pattern is generated through the encryption algorithm, known only to the manufacturer NITGEN, making it impossible to recover externally for calculation or reconstruction of the fingerprint.

- "When the user accesses the gym, they are first validated with an RFID bracelet. Once the bracelet is passed and the user is identified, if they have registered in the system the need to verify their fingerprint pattern, a new pattern is constructed in real-time—which is not stored—and is compared 1

to 1 with the stored pattern.”

Upon the termination of a member, their fingerprint pattern is no longer retained. “Currently, users do not have any other access system to the gym facilities.”

7. It provides the following documentation:

7.1- RECORD OF PROCESSING ACTIVITIES (RAT) OF THE ACTIVITY “MANAGEMENT OF MEMBER ACCESS TO CLUB,” which states, among other things, that:

- a. The data controller is LLEFISA S.L.
 - b. The exercise of rights is carried out against METROPOLITAN SPAIN S.L., differing from the content provided to the claimant.
 - c. The data processor is PROYECTOS VISUALES ZARAGOZA S.L.
 - d. The legal basis is the commercial contract and consent.
 - e. The purpose of the processing is the management of personal data of the members to allow them access to the facility.
 - f. Among the data processed is the fingerprint.
 - g. In the section “Data retention period,” it states: “During the duration of the membership. When a member terminates for any reason, the access bracelet will be returned and will be deleted.”
- In the section “categories of recipients,” it states that “none are foreseen,” as well as regarding “international data transfer.”

7.2- RISK ANALYSIS, dated January 30, 2020, references that the analysis “

conducted by METROPOLITAN SPAIN SL

”, and in the margin appears the name of the Company that conducts it. In the section “COMPLIANCE RISK” and in the section “associated with compliance,” it indicates that it concerns the use of the fingerprint, and, additionally:

- “RISK: Not providing all the information required by sections 1 and 2 of art. 13 at the time of collecting the data, when obtained from the data subject.

Why? The informative clause provided by the company for the processing of biometric data is complete, but in some cases, it must be explained personally.

Corrective measures: Provide complete information. Keep in mind that the information must also be provided to existing members.”

7.3- IMPACT ASSESSMENT, dated 02/05/2021, “Metropolitan Spain SL,” “AQUA FLORANES. Santander, belonging to LLEFISA SA. Biometric control opening system” (p. 48 point 6) conducted by the same company as the risk analysis seen in point 7.2, signed by the DPD of METROPOLITAN. It states that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/50

“The DPIA is conducted on the processing of data of the members of the data controller with the purpose of controlling access to the gym. The data processed includes the fingerprint or those identifying data necessary to be included in the member's identification bracelet, with the aim of allowing the system to recognize the individual and permit access to the gym through this identification. Additionally, the date and time of access are recorded.”

“2.- Procedure for comparing the captured data with the stored data

The user (member) validates first with an RFID bracelet when accessing the gym. Once the bracelet is scanned and the user is identified, if they have registered in the system the need to verify their fingerprint pattern, a new pattern is constructed in real-time that is compared one-to-one with the stored pattern through NitGen's internal algorithms. This pattern is generated in real-time and is not stored.”

“3.- Criteria for the encoding and storage of the captured information

A pattern generated through the encryption algorithm held by the manufacturer NitGen is stored in the user's profile. Raw data is not stored.”

According to the report, LLEFISA is responsible for the processing at the gym to which the complainant belonged and at "Palacio Santa Ana Madrid." It also refers to other gyms where the responsible party is METROPOLITAN.

a. There is a residual risk to rights and freedoms that does not exceed a medium level.

b. Regarding the necessity and proportionality of the processing, it states that:

"Starting from the compliance with one of the conditions for the lawfulness of processing set out in Article 6, paragraph 1(b), since it occurs as an activity framed within the execution of the membership contract, which the member reads and signs at the time of joining as a member and which regulates the relationship between the individual, the member, and the data controller, the Club METROPOLITAN AQUA FLORANES, we must analyze the necessity and proportionality of this processing.

To the above, it should be added that the data is collected for access and use of the gym and members cannot be identified for purposes other than that access, remaining as members of the gym; in the contract, the fingerprint procedure is informed, and if the client agrees, they sign the contract and access the Club, and if they do not agree, they do not become a member."

7.4- A copy of the data processing agreement, signed and dated December 30, 2018, is provided, with LLEFISA S.L. (Metropolitan Aqua Floranes) as the data controller and PROYECTOS VISUALES ZARAGOZA S.L. as the data processor. Among other sections, it states:

a. The object of the agreement is the service of installation and maintenance of the management and access control application for the sports facilities.

b. The processor must process the existing data in the PROVISPORT application, whose usual content includes data of members and users of the Club of the following types: identification and contact data, biometric access to the sports club (hash codes)..."

7.5.- Report from "October 2019" signed by the DPD of METROPOLITAN, regarding "feasibility of implementing a biometric system for accessing the facilities of the Metropolitan centers." Among other indications, it states that data related to fingerprints must be subject to the regime provided for special categories of data as set out in both Article 9 and other articles of the GDPR. According to these considerations, the processing of biometric data will require not only the concurrence of one of the legal bases established in Article 6 of the GDPR but also that one of the exceptions provided for in Article 9.2 of the GDPR must apply.

7.6- Letter from NITGEN Biometrics Solutions, from NITGEN Co, Ltd., based in South Korea, regarding the fingerprint data extracted by its readers. It states that "they cannot be decrypted or dismantled by any unauthorized entity," and that "the only keys for the algorithm are held by NITGEN and are not available to the personnel who distribute or compare the equipment." "Once scanned and converted to the NITGEN fingerprint pattern, the scanned image is destroyed. All that remains is a mathematical model that cannot be decoded to obtain the image of the original fingerprint."

- "The total number of individuals with stored fingerprints currently is 1356," which matches the total number of registered users.

FIFTH: As a result of the information request made to METROPOLITAN SPAIN, S.L. by the inspection, dated 10/05/2022, the aforementioned entity submits the following information and statements to this Agency:

1. It provides a copy of the "co-responsibility agreement" between LLEFISA S.L. (METROPOLITAN AQUA FLORANES) and METROPOLITAN SPAIN, S.L., signed and dated May 25, 2018.

In the EXPONEN, it states:

"Both companies have jointly determined the objectives and means of processing, therefore they are considered co-controllers of the processing of the members of the AQUA FLORANES Sports Club."

In the clauses, the first one has marked crosses in:

"Common objective regarding processing"

"Processing of personal data for the same purpose"

"Use of the same set of personal data - member database - for processing between both controllers"

"Design of the joint process"

"Common rules for handling information between both controllers"

In the second clause, it is indicated that they are co-responsible for the processing of personal data related to the management of members of the "CLUB AQUA FLORANES." "The treatments to be carried out are": member registration and deregistration, access control to facilities, and fee management.

In the third clause: "Obligations of the co-responsible parties for the processing," it is stated:

- The co-responsible parties are obliged to respond to the interested parties regarding the exercise of their rights before anyone.
- "The co-responsible parties, at the time of data collection, must provide information regarding the data processing that will be carried out, including the identity of the various data controllers; for this purpose, it is mentioned in the member registrations to LLEFISA SA, owner of the Santander facility, and to METROPOLITAN SPAIN SL, owner of the METROPOLITAN brand and the management of sports centers."
- "The co-responsible parties will notify the other data controllers of any data security breaches..." without specifying who those other "data controllers" are.

In item 6, it is indicated: "to jointly carry out impact assessments related to data protection, when appropriate."

2. Provides copies of invoices, orders, and contracts in the name of METROPOLITAN SPAIN SL dated 19/01/2017, "TWO SQL SERVERS," CONTRACTED SERVICE "CLOUD," according to METROPOLITAN, "servers where the PROVIS software is located."

3. It states that "the user record" in the PROVIS software consists of a series of interrelated records in a database, with the PROVIS software being an "ERP for management, billing, and specialized access control for sports centers."

- In the database of the PROVIS software, a pattern is stored generated through the private algorithm of the manufacturer NitGen.

The RFID wristband carried by the members only stores a UID (unique identifier), no pattern is stored. It adds that "The RFID reader activates the fingerprint reader, this does not provide direct access."

4. It states that the configuration option, "Allows cold search," which means searching for type 1 fingerprints: N, is not selected.

It provides a screenshot of its systems showing the option "Allows cold search" not selected.

5. It provides an extract from the database with the last 100 user deregistrations where the fields "Person ID" and "Last deregistration date" are listed. It provides an extract from the database with the last 100 deleted fingerprints with fields, among others, "Date" and "Person ID." In the extract of deleted fingerprints, the "Date" field takes values between "25/05/2021" and "25/04/2022." It is verified in these extracts that there are users who have been deregistered but for whom there is no record of fingerprint deletion.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/50

6. Three extracts from the database are provided regarding the "total number of people whose fingerprints are stored," "total number of people registered in the fingerprint access system," and "total number of people registered as gym users," with these extracts being identical and with a total number of people in each case of 1387.

The three previous extracts are obtained with the same search parameters, and each of the three lists contains the following text: "Generated on Thursday, May 5, 2022, at 12:38:00."

7. On 13/07/2022, it is verified that at the URL

<https://provis.es/wp-content/uploads/2019/05/MANUAL-Completo.pdf> the manual for the PROVISPORT software for "management and access control in sports facilities" is available, where a screen of the software similar to that provided by the accused is included, and it is also stated in this manual that "If the fingerprint reader allows cold search, it allows the possibility of authenticating clients using only their fingerprint without previously entering any PIN number."

SIXTH: On 3/08/2022, the Director of the AEPD agreed:

"TO INITIATE SANCTIONING PROCEDURE against LLEFISA, S.L., with NIF B60422417, for the alleged infringement:

- Of Article 13 of the GDPR, classified in Article 83.5.b) of the same GDPR, and for the purposes of prescription, classified as minor in Article 74.a) of the LOPDGDD.
- Of Article 7 of the GDPR, classified in Article 83.5.a) of the GDPR, and for the purposes of prescription, classified as very serious in Article 72.1.c) of the LOPDGDD.

"for the purposes provided in Article 64.2 b) of the LPCAP, the sanctions that may correspond would be fines of €2,000 and €15,000, as specified, without prejudice to what results from the instruction."

SEVENTH: According to the certificate of telematic notification, it appears with the following result:

Date of availability: 05/08/2022 11:54:03

Date of automatic rejection: 16/08/2022 00:00:00.

In order to ensure receipt of the agreement, in application of Article 41.6 of the GDPR, and since there is no email address for the accused, nor electronic device to be informed of the availability of the notification in electronic headquarters, the initiation agreement was sent by postal mail, being received by the accused.

EIGHTH: On 31/03/2021, a letter from LLEFISA is received. The person making the allegations, in addition to being the data protection delegate, is the same person who submitted the responses on behalf of METROPOLITAN during the transfer of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/50

claim, also appearing under this category in said entity, and the one that presented all the documentation. It indicates that METROPOLITAN was linked to LLEFISA until August 2022. It requests the dismissal of the file and that the proceedings be archived. It states:

1. LLEFISA cannot be considered as claimed because the claimant identifies METROPOLITAN SPAIN SL as such and the transfer of the claim was made to that entity, with LLEFISA not being responsible for the actions of METROPOLITAN.

2. The reading in the contract signed by the claimant regarding: "The biometrics and the bracelet must act together to access the center, not being operational independently. These are necessary service conditions for the proper functioning of the center, and if not accepted, it prevents us from providing the service to the member.", we maintain that in the phrase "it prevents us from providing the service to the member. LLEFISA, SL, does not refer to preventing a person from being a member as the complainant has attempted to reflect, wanting this AEPD to consider it a defect of consent for not being free."

Regarding the statement: "That the biometric system was installed in this Club Aqua Floranes in February 2021 as the only means of access linked to the bracelet," this does not correspond to reality: it was not the only means of access. At no time were the biometric data of the claimant obtained, and, however, during the time she continued to be a member of the club, until June 2021, she made use of the facilities entering through the access control without using biometrics at any time, given that her refusal to provide it was respected, and the same applies to other members. This assertion is corroborated by the record of the claimant's access to the facilities without biometric access until the date of her resignation and with the copy of her file where it is stated that no biometrics are recorded (provides Documents No. 1). In the same, an Excel list appears, name and surname, by date, from 1/02 to 6/05/2021 (search until 31/07/2021), entry and exit time, and the computation of the time spent as "stay." In that list, there is no relationship of card or access system. It also includes the PROVISPORT file of the claimant that contains her data and photograph, from which the previously mentioned Excel list is extracted or seen and a card number.

A record of access to the facility of other members is also provided, "PROVISPORT files" without recorded biometrics, as well as images of their files (provides document No. 2). In the same, as indicated, it corroborates the non-obligatory nature of having registered biometrics to access the facilities.

Regarding what is indicated in point 6, that “currently users do not have another access system to the facilities,” it should be clarified, as “there are alternative systems to access the facilities, such as the “manual access control by presenting ID for verification at reception, through the comparison of the photograph that appears in the PROVIS file versus the ID. However, the bracelet and hash code control system is prioritized to expedite access and give total autonomy to the member to enter and exit the establishment without waiting for reception to open the turnstile or access door.”

3. The type of data processed to access the facilities through fingerprint is biometric, but not of a special nature, considering that there is differentiation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/50

between processes that involve biometric identification and those that involve biometric verification/authentication. In the first, the data acquired at the time of identification is compared with a series of templates stored in a database; the search process is one-to-many. It considers that these would be regarded as specially protected, falling within the general prohibition and exceptions of Article 9 of the GDPR.

In the second type of processes, the data acquired at the time of verification is compared with a single biometric template stored on a device; the search process is one-to-one. It estimates that the system used for controlling user access to the gym facilities in Santander, which the claimant attended, “authenticates that the person wearing the wristband and placing their finger on the system is the same.” It considers that these, which are used for access control, would not be specially protected and would not fall under the prohibition established in Article 9.1 of the GDPR. Along with this consideration, the aggravating circumstance of the infringement of Article 83.2.g) would fall away due to the data not being specially protected and its implications.

4. Regarding the incomplete nature of the accusation under Article 13 of the GDPR, it indicates:

a) “The regulations signed by the claimant were produced before the implementation of biometric access,” “and therefore the information about the new access system was provided through signage placed at the reception, the publicity of the NITGEN system, and a person at the turnstile entrances.” It attaches Document 11, which consists of a sheet titled: “METROPOLITAN Sport Club & Spa Personal Data Processing” without a date. It begins with “METROPOLITAN complies with all the requirements established in the GDPR...”, highlighting that the data provided, including biometric data, is processed by METROPOLITAN for the purpose of managing the request for membership at the gym and inherent purposes, such as the management and collection of fees, and access to the facilities.

The retention period for biometric data is recorded in the activity log, which is until one ceases to be a member of the Club or until the right of limitation or deletion is exercised. “Regarding the possible communication of data to third parties,” the non-existence of such communication and due to a need to minimize the text in the drafting of the regulations at that time by the existing staff, it was not mentioned that “biometric data would not be communicated to third parties,” a mention that is obvious for the responsible party based on the Risk Analysis and the DPIA. Since no profiling was produced or carried out, this was not mentioned, considering that “if a certain data processing is not carried out, it was not necessary to mention it.”

In the “current member regulations” of AQUA FLORANES, the three referenced sections are now mentioned. It provides Document 12, which it states contains current member regulations, allowing to ascertain that there is no ongoing infringement of the right to information, and that there has been no benefit as a result of not having informed about the data retention period. Document 12 is viewed, which deals with a model, does not contain an implementation date, and contains the Clauses of the contract for the use of the Club's facilities, “member regulations” in which the section is now integrated: “authorization for the processing of personal data by the entity.” It contains:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

"We inform you that LLEFISA, SL complies with all the requirements established in the GDPR 2016/679 (EU) and that all data under our responsibility has been treated in accordance with legal requirements, maintaining the necessary security measures that guarantee the confidentiality of this data. The personal data you have provided, including your name and surname, ID number, postal and/or electronic address, as well as your credit card number or bank account, will be processed by LLEFISA SL, with CIF B60422417 at c/ Cisneros nº 67, 39007-Santander for the purpose of managing your application for membership at the gym and related purposes such as the management and collection of fees, and access to the facilities."

"To protect the safety of individuals accessing the center and their belongings, as well as the facilities themselves, a biometric access system (encrypted hash code) and a personal wristband that will complement the biometric use have been chosen. Such biometric data will not be subject to any other processing by LLEFISA, SL or by the IT service provider, except for maintenance services. The retention period for such personal data will not exceed the moment the member cancels their membership for any reason or requests deletion. No automated decisions will be made nor will profiles be created with such data. The biometrics and the wristband must work together to access the center, and they will not operate independently. These are necessary service conditions for the proper functioning of the center and access control for members only. Alternative access methods may be used."

"Finally, it is informed that among other rights, you can exercise the revocation of the consent given for the processing of this data by directing your request to LLEFISA."

5. Regarding the lack of consent from the member at the time of signing the regulations, "these are necessary service conditions for the proper functioning of the center, and if not accepted, it prevents us from providing the service to the member," considering that it concerns the safety of individuals and belongings (machines, devices, facilities, etc.), "not access to the gym," for which there is no better way to verify that the individuals entering are indeed members of the center, who, in their own interest, will take care of their belongings and the equipment and machines with which they practice sports. The consent for the processing of biometric data or not, in no case conditioned the status of member, acceptance, and signing of the regulations, since there was another possibility for access. For such purposes, LLEFISA, SL has introduced biometric access control to ensure the proper functioning of the center and the safety of members' belongings, with almost all members considering it an improvement in the quality and safety of the center, while some (very few) have not agreed for various reasons and have not wanted to provide their fingerprint pattern to access the facilities along with the wristband, and it has also been noted that for "some elderly individuals," it has not been possible to obtain their pattern, and they have continued to enter without using biometrics.

For the purpose of proving that consent has been obtained to lift the prohibition on the processing of biometric data, as stated in Article 9.1.a) of the GDPR,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

LLEFISA acknowledges the consent of the interested party with the signing of the partner regulations. "It is also a clear affirmative act to technically proceed with the capture of the fingerprint pattern on the device (bracelet)." The consent of the partner is given in the context of the partner regulations, specifying the different treatments of their personal data. Additionally, AQUA FLORANES placed informational signage in 2021 at the reception of the center. Attached is document 11, which consists of a sheet titled "Treatment of Personal Data," containing information not about LLEFISA, but about METROPOLITAN as the entity that processes the data. It is indicated, in addition to the biometric registration and the bracelet, that "Another form of identification for access may be with the image of the partner momentarily displayed on a screen at the reception. If the access identification systems are not accepted, the Club will not be able to provide services to the partner nor allow their access to the

facilities."

It indicates that from that sign, another existing possibility to access the center is derived, which is the request for an ID card at the entrance and comparison with the image displayed on the reception computer screen. Only the non-acceptance of either of the two possibilities conditioned that the individual could not be a member of the gym, but at no time was the possibility of being a member conditioned on the acceptance of the biometric fingerprint, as was claimed by the complainant.

Consent should not be considered freely given when the interested party does not have true or free choice, or "cannot deny or withdraw their consent without suffering any detriment."

In this case, no detriment has occurred to the complainant or the other partners, as there exists another possibility of access to the center without a fingerprint, that of the image of the partner momentarily displayed on a reception screen, "and proof of this are the Excel files provided of all accesses between 1/02 and 31/07/2021, the date of their cancellation for whatever circumstance."

It is estimated that "the consent has been given freely since LLEFISA is not in clear imbalance with the complainant or partners in general, since neither AQUA FLORANES is the only sports center that citizens of Santander can attend, nor does it require membership by demanding the fingerprint of the individual."

As of the date of the complaint, LLEFISA is requesting consent for the processing of biometric data that was not considered, according to the criteria of the AEPD, as a special category of data, and that the partner provides "validly and expressly," while offering "alternative means to access the facilities," "without imposing the processing of biometric data as a mandatory requirement to access the facilities."

"When the biometric access control was implemented along with the bracelet, a member of the reception team was responsible for personally informing partners upon their access to the club, with the most evident consent being manifested through the personal and physical action of each partner in technically proceeding with the obtaining of the fingerprint."

6. With reference to the RISK ANALYSIS dated 30/01/2020, it indicates that it corresponded to the treatment system of METROPOLITAN AQUA FLORANES.

13/50

Some of the risks identified do not correspond to the actual situation regarding the responsible party LLEFISA, S.A., which is the subject of this Sanctioning Procedure.

One month before the implementation of the access control system with wristbands and hash codes, the DPIA for LLEFISA was signed on 31/12/2020. The DPIA document dated 5/02/2021 referred to METROPOLITAN. Attached is Document 4, which shows, "AQUA FLORANES SANTANDER - biometric control opening system." Noteworthy:

- "(7) The DPIA is conducted on the processing of data of the members of the data controller for the purpose of controlling access to the gym. The data processed includes the fingerprint or any necessary identifying data to be included in the member's identification wristband, so that the system recognizes the interested party and allows access to the gym through this identification. Additionally, the date and time of access are recorded."

- "(7.1) 2.- Procedure for comparing the captured data with the stored data

The user (member) validates first with an RFID wristband when accessing the gym. Once the wristband is passed and the user is identified, if they have registered in the system the need to verify their fingerprint pattern, a new pattern is constructed in real-time that is compared one-to-one with the stored pattern through NitGen's internal algorithms. This pattern is generated in real-time and is not stored." "d. Technology: identification or verification using a template stored during the registration process (unique code for each fingerprint, and the pattern is obtained with NitGen's mathematical algorithms)."

- "3.- Criteria for the coding and storage of the captured information. A pattern generated through the encryption algorithm held by the manufacturer NitGen is stored in the user's profile. Raw data is not stored. a. Process activity: data storage in the member's wristband."

7. There are no evident risks with the technology used to sufficiently guarantee to the interested party that the template obtained from the biometric data (1:1 hash code) will not match any other template or fingerprint used in other similar systems, and as the AEPD itself indicates, "it is undeniable that the use

of systems based on the collection of fingerprints to carry out access control in the gym avoids the risk of impersonation that could occur.”

8. Regarding the aggravation of the infringements:

- By applying Article 83.2 a) of the GDPR, it is considered that consent has been freely given and cannot be said to affect all customers of the entity; even the complainant was not affected, as they never provided their fingerprint and continued to attend the gym as many times as they wished using alternative means, as shown in the screenshot of the PROVISPORT management program, where their repeated entries and exits are noted without any biometric data recorded.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/50

- By application of Article 83.2.b), regarding the obtaining of consent for lawful processing, it acts diligently by being scrupulous in obtaining the free consent of its members and in the information provided about the new processing of biometric data for access control.

They have improved the wording so that the member perfectly understands the “authorization for data processing,” so that in the case “of not considering the access through biometric access control convenient,” they still have another option to access the gym that does not require the processing of biometric data. Attached is the new wording indicating that the data provided: name and surname, ID number, email address, credit card number or bank account... will be processed for the purpose of managing their application for membership in the gym and inherent purposes such as the management and collection of fees, and entry into the facilities. It continues:

“With the aim of protecting the safety of the individuals accessing the center and their belongings, as well as the facilities themselves, a biometric access system (encrypted hash code) and a personal wristband that will complement the biometric use is chosen. Such biometric data will not be subject to any other processing by LLEFISA, SL or by the IT service provider, except for maintenance services. The retention period for such personal data shall not exceed the moment the member cancels their membership for any reason or requests deletion. No automated decisions will be made nor profiles will be created with such data. The biometrics and the wristband must act together to access the center, and they will not operate independently. They are necessary service conditions for the proper functioning of the center and access control for members only. Alternative access means may be used.” Finally, the exercise of rights is informed, among which is “the opposition to processing and the revocation of the consent given for the processing of the same.”

9. Provides:

a) Certificate from the developer company of the PROVISPORT application (Proyectos Visuales Zaragoza SL) dated 28/03/2023 indicating that “It has been verified that a biometric validation system for clients or 1:1 search is being used. A combined system of RFID credentials is used to locate the client in the database and verify through the client’s pattern, stored and generated by the manufacturer’s algorithm at the time of registration, with the pattern captured at the time of access.

b) Record of processing activities, “management of member access to the club,” responsible for processing LLEFISA SL, exercise of rights of access, rectification, limitation, deletion, portability, and opposition: Calle Cisneros 67, Santander, legal basis: member regulations, contract, consent to provide their biometric data, type of data: name, surname, photograph, fingerprint, hash code, access frequencies, signature, and image, purpose of processing: management of personal data of subscribers to allow them access to the facility.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/50

Data retention period: while being a member. Categories of recipients: Not foreseen.

NINTH: On 13/04/2021, a resolution proposal is issued regarding the following:

“1- That the Director of the Spanish Agency for Data Protection sanctions LLEFISA, S.L., with NIF B60422417 for an infringement of:

- Article 13 of the GDPR, in accordance with Article 83.5.b) of the GDPR, classified for prescription purposes in the article of the LOPDGDD, with an administrative fine of 2,000 euros.

- Article 9.1 of the GDPR, in accordance with Article 83.5.a) of the GDPR, classified for prescription purposes in Article 72.1.e) of the LOPDGDD, with an administrative fine of 15,000 euros.

- Article 6.1 of the GDPR, in accordance with Article 83.5.a) of the GDPR, classified for prescription purposes in Article 72.1.b) of the LOPDGDD, with an administrative fine of 10,000 euros.

2- That the Director of the Spanish Agency for Data Protection orders LLEFISA, S.L. under Article 58.2 of the GDPR, to demonstrate a correct and adequate implementation of the fingerprint system, attending to the legitimizing basis for the processing of the data of the fingerprint register, to those who already have that data, and to the information related to the processing associated with it.

Delivery accepted on 14/04/2013.

TENTH: On 28/04/2023, they now have allegations in which they state:

1) They reiterate their claim that their biometric processing is for verification 1 versus 1 and not for identification and would not be considered special data, even though the processing is aimed at identifying a person. “In the same way that checking the ID card with the member's file is also aimed at uniquely identifying a person” and would not be classified as special category data.

The instructor has not addressed any of the technical arguments in the allegations that demonstrate that the technique used is secure. To date, there is no evidence that any security breach has occurred. It would be confirmed that the system guarantees that there are no obvious risks with the hash code template 1:1, “since it would not match any other template or fingerprint used in other similar systems.” “In the NitGen system, the reversal of the algorithm used is impossible.” “We cannot subscribe to the idea that in the face of a vulnerability, all access systems with biometric data are affected at the same time; each system has its own encryption code.”

The prohibition on the processing of biometric data, if this is the case, in this instance they consider that the circumstance arises that overcomes its prohibition given that the member has given explicit consent for the processing of such personal data for one or more specified purposes. This relates to the fact that the capture of biometric data such as fingerprints must be done consciously with the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/50

positive action to initiate treatment as is the case here, unlike other systems where the person is not aware that biometric information is being taken or when it is being taken.

For the system and access control to the Club, it does not matter what the user's name is; the only thing that is of interest and necessity is that the user is an individual registered in the system and is authorized to access the facilities as a member, with two purposes: one, that they are an active member and therefore up to date with their payment dues, and another, that they are not an unauthorized usurper who could compromise the security of the facilities and the people. The system does not aim to unequivocally identify the user but to verify that their data corresponds with the hash code and authenticate them as an authorized user for access to the club.

It is in the verification and authentication process that the correspondence with the registered parameter is established and therefore the member is validated, in the 1:1 procedure, distinct from the identification of 1: many, of the actual identification of the user that the respondent does not carry out at any moment.

2) Regarding the claim before Consumer, it states that the claimant only requested the form and did not submit it.

3) It is stated "in different points of their writing" as "proven fact" that "Currently users do not have another access system to the gym facilities," being a statement from the claimant that is not true and must be rejected, having demonstrated that there was informative signage at the reception of the center, document 11 of allegations, and that a list of users from 1/02 to 6/05/2021 who accessed

without biometric data was provided.

It states that "At no time was the possibility of being a member conditioned on the acceptance of the biometric fingerprint, as has been claimed by the complainant." The fact that members do not voluntarily provide their biometric data has no negative consequence or detriment to the member. It reiterates that there were alternative access systems, such as the presentation of the ID card in - comparative image displayed on the reception computer screen, which is derived from the sign. Only the non-acceptance of either of the two possibilities conditioned that they could not be a member of the gym, but at no time was the possibility of being a member conditioned on the acceptance of the biometric fingerprint, as has been claimed by the complainant.

4)

The current membership regulations are from 2023, of which the model was provided in allegations extracted from the computer system (so that personal data is not contained), although they had submitted 3 pages, they now provide the one that was missing, (document no. 2) "the authorization for the processing of biometric data." The document bears a signature line for the user and does not indicate when it comes into effect. Furthermore, it states:

"Condition of membership:

"The personal data you have provided, including your name and surname, ID number, postal and/or electronic address, as well as your credit card number or bank account, will be processed by LLEFISA SL. for the purpose of managing your application for membership."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/50

as a gym member and inherent purposes such as management and collection of fees, access to facilities, participation in events and master classes, etc. The data will not be transferred to third parties, no automated decisions will be made, nor will profiles be created with such data. There will be no international data transfers.

The retention period for personal data will be 5 years from the moment the member cancels their membership for any reason or from their request for deletion, in which case the data will be kept blocked until the deadlines required by tax regulations are met.

Access Registration

"As specified in the member regulations, in order to protect the safety of individuals accessing the center and their belongings, as well as the facilities and equipment themselves, LLEFISA, SL has opted for access management through a system using the member's biometrics (biometric registration with encrypted hash code) and a personal wristband that complements the biometric use. The biometrics and the wristband must act together to access the center, and they will not operate independently. These are necessary service conditions for the proper functioning of the center and access control for members. The purpose of this biometric access registration is to facilitate the verification and accreditation of membership status to prevent unauthorized access. The retention period for personal data will not exceed the moment the member cancels their membership for any reason or from their request for deletion. No automated decisions will be made, nor will profiles be created with such data. There will be no international data transfers. The characteristics of the NetGin system can be found at the center's Reception. It will be understood that you authorize the processing of biometric data if you consent to the collection of your fingerprint using the NetGin mechanism at the reception. Otherwise, you may use an alternative means of access by presenting your ID card or passport to the club's reception staff at each of your accesses, who will validate your status as an active member in the center's management program and proceed to a manual opening of the turnstile, without compromising your membership status. In accordance with current data protection regulations, you may exercise your rights of access, rectification, limitation, deletion, portability, and opposition to the processing of your personal data, as well as revoke the consent granted for their processing, indicating which right it concerns, by directing your request to LLEFISA, SL, c/ Cisneros nº 67,

39007-Santander or to the email dpo@wemet.es attaching a document proving your identity. You may file a complaint with the AEPD. MEMBER SIGNS IN AGREEMENT”

It is stated that they attach a sample authorization of signed consents that include personal data of members (documents 3 to 10) with the caution that they will not be made public at any time, being the signature of the aforementioned document “authorization for the processing of personal data,” in which the name and ID number and registration dates are mechanized as examples of dates: ranging from 19/02/2021 to 25/04/2023, (with document number 10 being a possible error, registration: 3/09/2013), without knowing if the registration date coincides with the date of this authorization as no date is indicated in the signature footer.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/50

5) It adds that in relation to point 2 of the Proposal for Resolution, the defendant, LLEFISA, SL, already demonstrates a correct and adequate implementation of the fingerprint system, addressing the legitimizing basis of consent for the processing of data from the fingerprint registry through a Tablet that generates the document provided as Document No. 2 (Authorization for the processing of biometric data) from those who were already members before obtaining such data and from those who join the Club as members (provided they facilitate it), in which the information regarding the processing associated with said fingerprint is detailed.

- In relation to point 1 of the Proposal for Resolution, the defendant, LLEFISA, SL, already provides the information required in Article 13 of the GDPR, albeit with the caveat that it refers to the revocation of consent and not the withdrawal of it, understanding it as synonymous actions for the purposes of its exercise, or that in any case the amount of the sanction of 2,000 euros should be reduced, considering the minimal infringement for not mentioning "withdrawal" instead of revocation of consent, or for not duplicating the terms.

6) It provides a chronological review:

October 2019: Report on the feasibility of using biometric data. Prior to the differentiation by the AEPD of identification-authentication 1:1 versus 1:N.

02/09/2020: registration of A.A.A. as a member of AQUA FLORANES when access control was not biometric.

02/09/2020: Signing of member regulations. Therefore, the signing of the Regulations does not contain a reference to such data processing, not being a breach because at that time there was no access registry with biometrics.

02/09/2020: Signing of the authorization for data processing for management as a member (access to the club, bank receipts, master classes, etc.) plus information about (1) AQUA FLORANES opting for biometric access control and (2) use of accessory platforms (Technogym, Trainingym, etc.) for which no type of authorization is requested because biometrics do not exist and the use of the platforms is a personal decision of each member.

30/12/2020: DPIA on the processing of access control with biometric data.

30/01/2021: Risk analysis before the installation of the biometric control system.

01/02/2021: Installation of the biometric access control system at AQUA FLORANES, not on the date 06/05/2021 as stated by the complainant.

01/02/2021: Informational signage of the new access system and personnel at the Turnstile (access control) informing about the system.

06/05/2021: Request for a complaint form by A.A.A.

01/06/2021: Termination of membership, without stating a reason.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/50

The account concludes that the contract from September 2020 could not reference biometric data because it did not exist; access control was managed through ID card + member file on the computer. This also rebuts the lack of information regarding the retention period of biometric data in the contract, information about recipients, or the existence of automated decisions:

The absence of reference in the impact assessment to other access modalities aside from biometrics was because it focused exclusively on that biometric processing, and therefore existing systems were not re-analyzed up to that point.

The new "member regulations" contract, which expanded the right to information, was provided in the model as it appears from the software program; hence it did not have a date. It had already been made available to members in January 2023, and the model for "specific authorization" had also been distributed to all members (those prior to the implementation of the new access registration devices in February 2021). Attached as Documents 3 to 10 are authorizations for the processing of biometric data corresponding to a sample of members from February 2021 to September 2022 (under the METROPOLITAN brand), documents from the period December 2022 to April 2023, as well as from members prior to February 2021.

The claimant is informed upon registration as a member about the use of a "biometric system" or "biometric registration," despite it not being in use yet for access to the facilities; however, no such data was collected at that time because the system was not operational. This differentiates the paragraphs regarding the processing of the data provided for the purpose of managing their incorporation into the club, collection of fees, and access to the facilities at that time, from the subsequent informative paragraphs: "opt for an access control system using fingerprint and wristband"; and the use of ancillary platforms. Such differentiation is made with complete transparency since there is no mention of any type of biometric data processing at that time because it did not exist in the Club. It is established that at that time biometric data was not processed by LLEFISA, SL, and it cannot be deduced or concluded that the contract signed by the claimant lacks information about:

- a) the legal basis for the processing of biometric data (it did not exist);
- b) the purpose of using the biometric system (it did not exist). At the time of becoming a member, only name and surname, ID number, postal and/or electronic address, and credit card number were provided.
- c) the possible communication of data to third parties did not occur.
- d) the retention period of the data. It is true that it was not indicated, but biometric data did not exist.
- e) whether automated decisions referred to in Article 22, paragraphs 1 and 4 of the GDPR, including profiling, would be adopted, and if so, about the logic applied and the importance and expected consequences of such processing for the data subject. No automated decisions are made, nor do the data in question exist.

Regarding the fact that the contract and the authorization do not indicate anything about access or alternative use to biometric registration, nor whether the communication of data...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/50

Personal data is a legal or contractual requirement, or a necessary requirement to enter into the contract, and if the interested party is obliged to provide personal data and is informed of the possible consequences of not providing such data, it is irrelevant because at that time biometric data was neither processed nor collected, so a breach of the legislation cannot be inferred as of that date. It indicates that "authorizations for the processing of biometric data began to be obtained with the implementation of the biometric access register—starting in February 2021—as can be deduced from document 2, and that in turn 'modified the information clauses in the regulations, which consists of three pages, and the last one contains the 'authorization for the processing of data by the type of biometric data.'

Thus, 'the information on the collection of data at the moment it is collected and will be processed was obtained through the framed poster at reception and a person who answered questions and doubts

about what the collection of the fingerprint implied, how it would be used, the technical sheet of the NitGen system; the capturing (positive physical action of the member) of the fingerprint and the express authorization of the members as they accessed the club (only from the members who authorized the processing of the fingerprint, so it is obvious that AQUA FLORANES did not have at any time the signed authorization from the claimant).'

"Although members were previously informed (authorization) of a system that would be established in the future, this cannot be considered a breach or insecurity because the possible confusion of the interested party interpreting this AEPD was covered with effective information and consent (by physical action of providing the fingerprint) at the time of the system's implementation in February 2021 and signed authorization."

"We agree with this AEPD that in the subsequent processing that materializes when the claimant's data was intended to be collected, it is when the information about said processing must be completed, adapting to the processing operations that occur with the implementation of biometric access control and the taking and use of fingerprints for access to the club's facilities. In fact, the claimant never states that she was not informed about the processing; she was perfectly informed, nor that rights were violated, nor did she exercise any type of right before the Club or METROPOLITAN SPAIN, SL or LLEFISA, SL."

It considers that it did inform through an informational poster at reception and a person who "gradually obtained consent with the signing of the authorization."

"We do not understand that it is fundamental information to inform about aspects that do not occur or condition the facts. We must contradict the statements of this AEPD in the sense that, even if the claimant did not provide the fingerprint, LLEFISA, SL is considered exempt from the obligation to provide such information, since THIS INFORMATION WAS PROVIDED THROUGH THE POSTER AND THE TECHNICAL SHEET OF THE SYSTEM."

"LLEFISA, SL cannot provide the authorization of this member for the processing of her biometric data because such authorization did not exist and biometric data of the member in question was never processed."

7) It does not agree with the AEPD's assessment that there is no reference to consent as a legitimizing basis for the processing of the biometric register for the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/50

access to the gym of the defendant, since on the date of their incorporation "such biometric data was not being collected." The paragraph referring to "METROPOLITAN opts for the system..." is merely informative for the same reason (it was not necessary to request authorization because biometric data was not being collected in September 2020).

For the rest of the members who authorized the collection and processing of the fingerprint, we have the positive action of providing the fingerprint to be collected in the system and the authorization signed on the Tablet as clear evidence of the members' consent for the processing of such data. This implies that consent is the legal basis for the processing of biometric data, so the other legal bases contemplated in 6.1 of the GDPR, which involve the "necessity" of processing, do not apply in this case.

Regarding the assertion of the proposal that states, "even if there was (consent), it should have foreseen the option of not granting it without any negative consequences; it is not considered an adequate legal basis for the processing of data in that modality with the provision of this service, unless a different real and effective alternative to the use of the fingerprint was provided." It has been demonstrated that members had other modalities of access to the club (ID verified against the member's file), that the member in question accessed from the implementation of the fingerprint in February 2021 until they canceled their membership in June 2021 without providing the fingerprint, but instead of considering that LLEFISA, SL provided alternative means and therefore the consent was free and had no repercussions for the members, they state that it has now become UNNECESSARY.

"We reiterate that, for the provision of the service, understanding service not as access to the club, but as the sports service of machines, trainers, equipment, etc., a good control of access to the facilities is necessary. That is why we must be especially attentive and not conflate under the same concept 'service' the activity of the club (provision of sports services) with access to it, which is not any type of service but a means to enjoy the service (the good service) with safety, discretion, and correctness. The control of access, as rigorous as possible, is what makes the club provide a good service to its members. That is why, at no time is it intended to establish that for the provision of the sports service(s) "the use of the fingerprint was or is necessary" because at no time is this the issue subject to the complaint and the initiation of the sanctioning procedure.

We must reiterate that the voluntary option to provide the fingerprint or reject the collection procedure has not been violated at any time, and that no member has suffered any negative repercussions.

"No one can prove that there was any type of retaliation for not providing the fingerprint. Not even the complainant can prove any retaliation such as being expelled from the club for not having provided their fingerprint. They stayed until they wanted to, that is, until summer came and they canceled their membership because they were no longer interested (presumably). All members were provided (with the poster and the technical information of the system) both the information on its use and a free alternative for those who did not wish to grant such explicit consent (authorization signed on the Tablet) and therefore did not facilitate the biometric data collection procedure."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/50

The AEPD cannot assert that in the case of LLEFISA, SL "the establishment of consent as the legal basis for processing in the use of fingerprint data affects the provision of the contracted service, conditioning it on the acceptance of those processing modalities, due to the legal position of the data controller." This is a false statement. Access is allowed under other modalities, and it has been demonstrated that the obtaining of biometric data is not conditioned on the provision of sports services and membership status.

8)

Regarding the explicit reasons for why an administrative fine procedure is warranted, the AEPD states "due to the importance that, in the provision of a paid service, all data processing requirements are fully met, ..." it considers that this aspect is not relevant to differentiate it from what would be public entities or based on the type of services as an aspect to be taken into account to demand greater compliance with the relevant regulations.

9)

It is evidenced for the purposes of absence of culpability that the defendant conducted a risk analysis as stated in Article 32.2 of the GDPR. "From the aforementioned risk analysis, where the possibility or probability of various threats materializing was evaluated, a risk treatment plan emerged through which, by implementing certain measures (irreversible hash code), the inherent risk of processing was reduced, thus fulfilling the requirements of Article 32.2 of the GDPR."

Moreover, "the sanction is disproportionate considering that in the infringement of Article 9.2.b) in relation to Article 6.1 of the GDPR, the aggravating factors of Article 83.2.a) of the GDPR cannot occur, since the infringement is already of a very serious nature; that same intrinsic seriousness of the infringement cannot be used to add an aggravating factor," "since it would mean that the same conduct is being sanctioned twice."

Regarding the application of Article 83.2.b) of the GDPR for the same reason, the intent or negligence in the infringement is already incorporated in the type that is sanctioned, representing a fictitious accumulation of aggravations that is not appropriate.

Additionally, in relation to Article 83.2.a), it states that out of 1000 members, only one has filed a complaint, disagreeing that all affected individuals are included, as they are individuals who have not been affected at any time nor have they expressed such, but rather when they were informed of the new registration system, they accepted by providing their fingerprint and signed the authorization or

did not sign it, without any impact and without negative consequences from the Club, with members continuing to access through other alternative means to biometrics.

It considers that the aggravating circumstances of Article 83.2.g) would not apply to the sanctioned behaviors, as LLEFISA, SL did not engage in such behavior in relation to Article 9.1 of the GDPR. If the processing of a special protection data requires the consent of the data subject, freely given, the positive action (placing a finger on a device the first time to capture the fingerprint) and the authorization with the signature on a Tablet, imply and demonstrate that there are no circumstances that aggravate the conduct since consent has been obtained for the collection and processing of special protection data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/50

A non-reversible pattern cannot be used outside the NitGen system nor with any finger other than that of the interested party, therefore there is no type of damage, either present or future, to reputation, confidentiality, or that could cause social or economic harm.

It is also not in agreement with the consideration of the aggravating circumstance of 83.2.k) of the GDPR in relation to art. 76.2.b) LOPDGDD, that is, the link between the business activity of the defendant (sports activity) and the processing of personal data, implying the requirement for diligent compliance with the principles governing the processing of personal data and the quality and effectiveness of the technical and organizational measures that must be implemented to ensure respect for this fundamental right of both its clients and third parties. They believe that their activity consists of providing clients with machines, equipment, and trainers, for which they do not need to process, nor do they habitually process, personal data.

"Having data of members in the computer systems to verify them as members and charge them their fees should not be confused with the company's core activity. The activity, according to the company's corporate purpose, is the PROVISION OF MANAGEMENT AND TECHNICAL ADVISORY SERVICES, INCLUDING CONSERVATION, MAINTENANCE, EQUIPMENT, ADVERTISING, TECHNICAL, COMMERCIAL, AND ADMINISTRATIVE MANAGEMENT OF SPORTS OPERATIONS, ETC. "We are not talking about an insurance company, a healthcare center, an IT company or video surveillance company, nor a workplace risk prevention company; we are not talking about any of the activities listed in art. 37 of the GDPR or art. 34 of the LOPDGDD, whose types of data and categories of interested parties are presumed to be more sensitive."

- As elements they consider should be mitigating:

- o They have appointed a DPO since the moment they ceased to belong to the METROPOLITAN brand at the end of 2022, and since 2020 they were under the umbrella of the DPO of METROPOLITAN SPAIN, SL. Article 76.2 g of the LOPDGDD should be taken into consideration as a mitigating factor in the grading of the sanction, when it was not mandatory to have one.

- o The gym was closed from 14/03 to 20/06/2020 due to a government decision, presented an ERE due to the aforementioned circumstances, froze the members' fees during that period, had to invest in health safety measures for the post-pandemic, limited the capacity of members in the facilities for health reasons, and thus suffered economic consequences from which it has not yet recovered, the data of which they provide in an Excel (income and expenses for the period 2020-2022) as Document no. 13, which underwent a split from the METROPOLITAN brand in October 2022.

"The supervisory authority may consider reducing the fine based on the principle of inability to pay at this time, as well as the danger that the imposition of the fine will jeopardize economic viability and continuity." Document 13 is an Excel sheet, dated April 2023, containing data from the years 20 to 22, showing the evolution of the amounts of income from member fees for each, salaries and wages, company social security, and operating expenses, with a total of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

returns that are in the three exercises in negative, most importantly in 2020, almost triple that in 2022 (-134 thousand compared to -51 thousand) and revenues in 2022 of 782,724 euros compared to 479,943 in 2020, with an evolution in 2021 of 643,608.

o

Lack of trial period.

PROVEN FACTS

1) The claimant's complaint is directed against METROPOLITAN SPAIN, S.L. The claimant states that since September 2020 she was a member of the gym located at c/ Cisneros 67 bajo, in Santander, and that, since May 6, 2021, access to its facilities was imposed on users through fingerprint recognition. She adds that previously, she accessed using a wristband and an identification card that she passed "at the reception computer." She declares that she has refused to provide her fingerprint data.

2) METROPOLITAN stated in previous proceedings that the company owning the gym CLUB AQUA FLORANES, at the address indicated by the claimant, is LLEFISA SL, with the claimant registered from September 2, 2020, to June 1, 2021 (a record is provided with a photograph of the claimant and an attendance control page of accesses from April 14 to May 6, 2021, the last day of attendance, without biometrics). It is noted: March 11, 2021 "Refuses to provide biometrics...". METROPOLITAN and LLEFISA maintain relationships for the management and operation of gyms, each owning several centers as deduced, for example, from the risk analysis of January 30, 2020. The center to which the claimant belonged is referred to in the impact assessment of February 5, 2021, as METROPOLITAN AQUA FLORANES -Santander, owned by LLEFISA SL, being this company responsible for the aforementioned center in the cited EIPD signed by the same person who makes allegations on behalf of LLEFISA, and DPD of this, EIPD, which was provided by METROPOLITAN. In allegations to the agreement, LLEFISA provides another impact assessment dated December 31, 2020, listing the gyms owned by LLEFISA and with the same purpose, conducted by the same company, and signed by the same person.

METROPOLITAN also provided:

a) COPY OF CONTRACT between LLEFISA S.L. ("METROPOLITAN AQUA regulations") and the claimant, dated September 2, 2020, containing the claimant's data and stating that to access the gym, members have a personal and non-transferable wristband and that to access the facilities, the use of a biometric system along with the access wristband is necessary. It also informs about the possibility of exercising rights, among which is mentioned the "revocation of the consent granted for the processing of the same," directing the request to LLEFISA, SL. The contract states that the claimant authorizes LLEFISA to charge the payment of the fee and that it will provide the services of using facilities and sports equipment with access to the center.

b) Document of the same date, titled "AUTHORIZATION FOR DATA PROCESSING," in which it is stated that the "personal data you have provided of name...

25/50

First and last names, ID number, postal and/or electronic address, as well as the number of your credit card, will be processed by LLEFISA SL, SL... for the purpose of managing your application for membership at the gym and inherent purposes such as the management and collection of fees, access to the facilities, participation in events and master classes, etc. In order to protect the safety of individuals accessing the center and their belongings, as well as the facilities themselves, METROPOLITAN opts for an access system using biometric registration (encrypted hash code) and a personal wristband that will complement the biometric use. Such biometric data will not be processed in any case by Metropolitan. The biometric system and the wristband must work together to access the center, and they will not operate independently. These are necessary service conditions for the proper functioning of the center, and if not accepted, we are unable to provide the service to the member.

"

Nowhere in the contract or the so-called authorization is there any reference to consent for the

processing of biometric registration data (specified as the fingerprint), its collection, and the possibility of withdrawing it at any time related to it, nor is its collection required for the use of the fingerprint, imposing it as a condition for acquiring membership, using the services, and accessing the center with the aim of protecting the safety of individuals accessing the center and their belongings, as well as the facilities themselves. The authorization is the option selected by the claimant according to the contract and the "authorization." No other means of access to the facility is indicated. On the other hand, the fingerprint was not established in that gym at the time of the contract, and according to the claimant, it was established on 6/05/2021, while the respondent claims it was from 1/02/2021.

Neither in the contract nor in the authorization is there any information about the legal bases legitimizing the processing, nor about the specific one for biometric registration for access to the gym. The claimant did not provide the fingerprint for access to the gym, and it is noted that she attended until 6/05/2021, being discharged from LLEFISA on 1/06/2021, stating that she refused to provide the fingerprint and submitting a complaint form to Consumer filled out on 6/05/2021, without any evidence of submission of that same copy to the D.G. of Commerce and Consumption as indicated on the same form.

1)

In the activity register of the processing (RAT) of LLEFISA "activity management access members to the club," for which LLEFISA SL is responsible, it is indicated that the legal basis is "members' regulations, contract, consent to provide their biometric data," while in the contract and the authorization dated 2/09/2020, it is noted that there is no reference to the legal basis for the processing of the fingerprint. In the RAT, it states that the purpose of the processing is the management of personal data of the subscribers to allow access to the facility, with the fingerprint being among the data processed. This purpose stated in the RAT "to allow access to the facility" contradicts the purpose stated in the contract and in the data processing authorization, which states: "to protect the safety of individuals accessing the center and their belongings, as well as the facilities themselves, being a necessary service requirement or condition for the proper functioning of the center," while the DPIA provided by LLEFISA conducted on 31/12/2020 by the same DPO of METROPOLITAN, who signed the note on the "viability" of the processing of the fingerprint, in October 2019, indicates that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/50

It responds to the need to control access to the facilities. It is highlighted in point 7.2 of the DPIA regarding the necessity and proportionality of the establishment of the processing, the need to control adequate access to the facilities and for the security of its equipment and others, preventing unauthorized persons from accessing it, avoiding the use of cards that can be exchanged with other users, without providing data or indicators on the incidence and frequency of such accesses, or impact on the safety of individuals or belongings. Regarding proportionality, it details that "data is collected for access and use of the gym, and members cannot be identified for purposes other than access control in the facilities, and data will be deleted when the member cancels their membership; the contract (member regulations) will inform about the fingerprint procedure and if the client agrees, they will sign the regulations and access the Club, and if they do not agree, they will not be able to access."

It also states:

- "data retention period" indicates that, during the validity of the membership, and when the member cancels for any reason, the member will return the access bracelet and it will be deleted. However, the contract or authorization does not indicate anything about the retention of fingerprint data, nor about the recipients or categories of recipients of personal data, nor about the existence of automated decisions, if applicable.

4) In another DPIA provided by LLEFISA regarding "the opening system through biometric control" dated 31/12/2020, it is indicated among other circumstances, that it is carried out based on the fulfillment of the criteria that the treatments may involve automated decision-making, and involve the

use of biometric data for the purpose of uniquely identifying a natural person and that the process of use will begin in the first quarter of 2021. Section 7 states that "The data processed is the fingerprint or those identifying data necessary to be included in the member's identification bracelet, with the purpose of allowing the system to recognize the interested party and permit access to the gym through this identification. Additionally, the date and time of access are identified."

After indicating that the fingerprint is captured and recorded and stored in the application database (PROVIS) through a transformation into a pattern with an algorithm, a pattern generated through the encryption algorithm in possession of the manufacturer NitGen is stored in the user's profile. Raw data is not stored.

When the user accesses the gym, they are first validated with an RFID bracelet; once the bracelet is passed and the user is identified, if they have registered in the system the need to verify their fingerprint pattern, a new pattern is constructed in real-time that is compared one-to-one with the stored pattern through NitGen's internal algorithms. This pattern is generated in real-time and is not saved.

The DPIA indicates that the legal basis for the processing derives from Article 6.1.b), as the user has the status of a party to the contract as a member with LLEFISA, and regarding the specificity of the prohibition of processing biometric data, it does not indicate any aspect, despite the fact that, in the report, the same DPO emphasized the prohibition of this type of data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/50

5)

In preliminary proceedings, METROPOLITAN stated that all users registered at the gym have their fingerprints stored, totaling 1356 users, without specifying which center(s) they correspond to. LLEFISA in its allegations indicates that the registry covers about one thousand users.

6)

The process of using and registering the fingerprint for access to the gym begins with obtaining the user's fingerprint from a template. The template is generated with an encryption algorithm (known only by the manufacturer, NITGEN). In the user-member file in the software "PROVISPORT," the template generated through the encryption algorithm of the manufacturer NitGen is stored. In PROVISPORT, LLEFISA stores the data of club members and users. LLEFISA has a data processing agreement for the fingerprint access system contracted on 30/12/2018 with PROYECTOS VISUALES DE ZARAGOZA, which is also the owner of the PROVISPORT application used for storing and managing the fingerprint template.

In this specific case, by alternating the use of an RFID wristband, the user first validates with the wristband that carries a unique identifier. "Once the wristband is passed and the user is identified, if they have registered in the system the need to verify their fingerprint template," a new template is constructed in real-time that is compared one-to-one with the stored template through the internal algorithms of NitGEN. This template is generated in real-time and is not saved. "d. Technology: identification or verification using a template stored during the registration process (unique code for each fingerprint, and the template is obtained with the mathematical algorithms of NitGen).

The fingerprint template is retained while the user is a member of the Club and uses the access wristband until the user has ceased to be a member. Through the aforementioned software, deletion and erasure are executed.

"3.- Criteria for the coding and storage of captured information

A template generated through the encryption algorithm held by the manufacturer NitGen is stored in the user's profile. Raw data is not stored."

In the section evaluating the necessity and proportionality of the processing, it is indicated that it is based on compliance with lawful processing conditions under Article 6.1.b), given that it occurs as an activity framed within the execution of the membership contract, which the member reads and signs at

the time of registering as a member and which regulates the relationship between LLEFISA and the member. Regarding the necessity to adequately control access to the Club, restricted solely to members and employees of the Club, "it is clearly evident that any organization requires control systems, whether through personal control or automated control, for proper access to the facilities and for the security of its equipment and other assets." As for proportionality, it refers to the ruling in the FITNESS MURCIA case, SAN 1066/2020, decided before the entry into force of the GDPR. It adds that the data is collected for access and use of the gym, and members cannot be identified for purposes other than access control in the facilities, and the data will be deleted when they cease to be a member of the gym; the contract (membership regulations) will inform about the fingerprint procedure, and if the client agrees, they will sign.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/50

to the regulations and will access the Club, and "if they do not agree, they will not be able to access." The EIPD does not refer to other access modalities other than biometric, although it adds that "It is true that the entity expresses the priority of this access system to prevent other people from using the facilities, and opts to limit access without this device. However, for specific cases, it will facilitate access by providing a document proving identity, displaying a member's record on a computer screen, etc., although it will not advertise this."

In one of the conclusions, it states that "In the members' regulations (equivalent to the contract), LLEFISA, SL, will inform about the new data processing starting from its implementation and will be attentive to the level of awareness of the same."

7) LLEFISA has changed the wording of the "members' regulations" contract and the "authorization for the processing of personal data," providing its new wording in allegations and proposals.

The "authorization for the processing of personal data" consists of information on data collection, referring to the "members' regulations" specifying that apart from the data for the management and collection of fees and entry into the facilities (with name and surname, ID number, postal and electronic address, and bank card or account number) and its required retention period, there is a specific section on "access records," in which the OPTION taken by the respondent is explained, and which is previously mentioned in the "members' regulations" contract to implement the modality of "access through a system with the member's biometrics - biometric registration with encrypted hash code - and a personal bracelet" that complements the biometric use (it does not specify the content or reference of the data contained in the bracelet nor the system on which the aforementioned biometric record is based, as there may be several), continuing to inform that it will be used:

- For the purpose of protecting the safety of the individuals accessing the center and their belongings, as well as facilities and equipment
- Being a necessary condition of the service for the proper functioning of the center (it does not detail in what sense or convenience or interest and positive impact this use provides or how it contributes to the proper functioning of the center), and
- It also serves as "access control for members."
- "The verification of this access record with biometrics is to facilitate the verification and accreditation of the member's status to prevent unauthorized access."
- "It will be understood that you authorize the processing of biometric data if you provide your fingerprint using the NETGIN mechanism at the reception."
- "Otherwise, you may use an alternative means of access by presenting your ID or passport to the club's reception staff at each of your accesses, who will validate your status as an active member in the center's management program and proceed to a manual opening of the turnstile without compromising your status as a member."
- Signature of the member in agreement.

It is considered that this document does not obtain consent for the processing of data as it does not

specifically inform what type of biometric data will be processed; the "signature in agreement" document must be signed in bulk, while at the same time offering another option that cannot be selected at that moment and which is more burdensome, with the obligation to present a document each time access to the facility is made.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/50

as is the DNI. It is estimated that such "signature of conformity" constitutes mere information, without a concrete possibility at that moment to consent to the use or non-use of the biometric system, or the alternative system.

Furthermore, it continues to fail to inform about the legitimizing basis for the processing by stating: "It will be understood that you authorize the processing of biometric data if you provide your fingerprint using the NETGIN mechanism upon reception," which, on the other hand, contradicts the definition of consent:

"any expression of free, specific, informed, and unequivocal will by which the data subject accepts, either by means of a declaration or a clear affirmative action, the processing of personal data concerning them."

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, to the extent that they do not contradict them, by the general rules on administrative procedures in a subsidiary manner."

II

Article 70 of the LOPDGDD establishes the responsible parties, stating:

"1. Those subject to the sanctioning regime established in Regulation (EU) 2016/679 and in this organic law are:

a) The controllers of the processing.

(...)"

In the present case, the complainant signed the gym membership contract with the entity LLEFISA, S.L., being the controller of the processing of their data, according to the information related to the processing of their data.

The transfer of the complaint or the entity against which the complainant is claiming is not decisive when it has been demonstrated that the complainant was a user of the aforementioned gym whose address is described and located, and that it is evidenced that they maintained the relationship with LLEFISA.

III

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/50

The claimant signed a contract and a PERSONAL DATA PROCESSING AUTHORIZATION with LLEFISA on 2/09/2020. It was indicated therein that the personal data "provided" would be processed

by LLEFISA SL, with the purpose of managing their application for membership at the gym and inherent purposes such as the management and collection of fees, access to the facilities...". Although it was stated that they were informed about the use of the "biometric system" along with the access bracelet, qualifying it as necessary, and that "if not accepted, it prevents us from providing the service to the member." It is evidenced that, at the signing of said contract, the fingerprint registration for access to the facility subject to the complaint was not operational. It is evidenced that in the "authorization," it does not state that at that time the fingerprint data was collected for that purpose, as it was not yet being used. In fact, the information did not specify but referred to a "biometric system and the bracelet." According to the claimant's statement, the specific and effective request for fingerprint registration occurred on 6/05/2021, a date that coincides with their last recorded attendance at the gym in the software application, as well as the note from the software application dated 11/03/2021, confirming that they refused to provide the fingerprint for registration.

It is deduced according to the DPIAs, two of which include LLEFISA, that its implementation was scheduled for the first quarter of 2021. It can be inferred that the claimant did indeed access, as stated, with the bracelet and a card (which appears in their profile in the application that had a card). The purposes stated in the information regarding the biometric registration and the bracelet contained in the contract and authorization are contradictory to those contained in the DPIAs and in the RAT of LLEFISA. In the contract and authorization dated 2/09/2020, a date when the fingerprint was still not in use, it is indicated that their data: name and surname, ID number are processed among other purposes, for entry into the facilities. It then explains that "In order to protect the safety of the individuals accessing the center and their belongings, as well as the facilities themselves, it opts for an access system through biometric registration (encrypted hash code) and a personal bracelet that will complement the biometric use," when it is evidenced that this was not initially the way the claimant accessed the gym.

It continues: "The biometrics and the bracelet must act together to access the center, and they are not operational independently. They are necessary service conditions for the proper functioning of the center, and if not accepted, it prevents us from providing the service to the member. In accordance with current data protection regulations, you may exercise your rights of access, rectification, limitation, deletion, portability, and opposition to the processing of your personal data, as well as the revocation of the consent granted for their processing, by directing your request to LLEFISA SL, c/ Cisneros nº 67, 39007-Santander." Information that does not align with the moment when the data is provided and the development of the facts, given that the claimant used the bracelet and card for access, making the fingerprint registration unnecessary, which would later become mandatory. Furthermore, there is no mention at any point of the provision/obtaining of consent.

Article 5 of the GDPR, relating to the principles governing the processing of personal data, mentions among them the principle of transparency. Section 1 of the provision states: "Personal data shall be: C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/50

a) treated lawfully, fairly, and transparently in relation to the data subject ("lawfulness, fairness, and transparency")"

The manifestation of the principle of transparency is the obligation incumbent upon the data controllers to inform, in accordance with Article 13 of the GDPR, the data subject when personal data is obtained directly from them:

"1. When personal data relating to a data subject is obtained from the data subject, the data controller shall provide the data subject with all the information indicated below at the time of obtaining the data:

a) the identity and contact details of the controller and, where applicable, of their representative;

b) the contact details of the data protection officer, where applicable;

c) the purposes of the processing for which the personal data are intended and the legal basis for the processing;

d) where the processing is based on Article 6(1)(f), the legitimate interests pursued by the controller or

a third party;

e) the recipients or categories of recipients of the personal data, where applicable;

f) where applicable, the intention of the controller to transfer personal data to a third country or international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49(1), second paragraph, a reference to the appropriate or suitable safeguards and the means to obtain a copy of these or the fact that they have been provided.

2. In addition to the information mentioned in paragraph 1, the data controller shall provide the data subject, at the time of obtaining the personal data, with the following information necessary to ensure fair and transparent data processing:

a) the period for which the personal data will be stored or, when that is not possible, the criteria used to determine that period;

b) the existence of the right to request from the data controller access to personal data relating to the data subject, and their rectification or erasure, or the restriction of processing, or to object to the processing, as well as the right to data portability;

c) where the processing is based on Article 6(1)(a) or Article 9(2)(a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of the processing based on consent before its withdrawal;

d) the right to lodge a complaint with a supervisory authority;

e) whether the provision of personal data is a legal or contractual requirement, or a requirement necessary to enter into a contract, and whether the data subject is obliged to provide the personal data and is informed of the possible consequences of failing to provide such data;

f) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4), and, at least in such cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

3. When the data controller intends to further process personal data for a purpose other than that for which it was collected, they shall provide the data subject, prior to that further processing, with information about that other purpose and any relevant further information in accordance with paragraph 2.

4. The provisions of paragraphs 1, 2, and 3 shall not apply when and to the extent that the data subject already has the information."

In this regard, Recital 60 of the GDPR states that "The principles of lawful and transparent processing require that the data subject be informed of the existence of the processing operation and its purposes. The data controller must provide the data subject with any supplementary information necessary to ensure fair and transparent processing, taking into account the specific circumstances and context in which the personal data are processed. The data subject must also be informed of the existence of profiling and the consequences of such profiling. If the personal data are obtained from the data subjects, they must also be informed whether they are obliged to provide the data and of the consequences of failing to do so."

The complaint we are examining concerns, among other issues, the compliance with data protection regulations of the information provided by LLEFISA when collecting personal data from a person who had been using the system with access through means other than fingerprint since its inception, 2/09/2020. Specifically, regarding the data of the use of the fingerprint for access to the gym, which is the subject of the complaint.

The complainant is informed upon registration of the use of their data, name and surname, ID number, bank account, for the management and collection of fees and access to facilities, adding that the respondent also opts for a "biometric system" or "biometric registration" despite it not being in use yet, without further specification among the multiple types of biometric data that can be used for access to facilities. Although no such data was collected at that time, it must be inferred that this data was not processed until the specific request for fingerprint registration was made to the complainant.

However, the information contained in the contract and in the data protection clause is noted.

C/ Jorge Juan, 6

www.aepd.es

Data signed by the claiming and claimed party, when the user is lacking information about:

- Legal basis for the processing, no mention is made regarding this, nor in the section titled "data protection," nor in item number 18 of the contract "Metropolitan AQUA regulations" where LLEFISA is expressly identified as the data controller.
- Lack of information regarding the purpose of using the biometric system, and in any case, this is not provided at the moment when the affected party is being asked to provide data. What the user signed should be considered in relation to the data they provide at that moment, and at that time, the fingerprint had not yet been established. They mention the name and surname, or the credit card, but nothing else is specified. Subsequently, it introduces the reference to the requirement for the proper functioning of the center, to protect the safety of the individuals accessing and their belongings, as well as the facilities themselves, from the center's option, the use, requirement, that access requires biometric registration and a wristband, but it was not yet operational at that time. On the other hand, this purpose for the biometric registration given then for the future does not match what is stated in the EIPD or in the RAT.
- Lack of information regarding the possible communication of data to third parties.
- The retention period of the data or, if it is not possible to establish a period, the criteria used to determine it.
- It does not inform whether automated decisions will be adopted as referred to in Article 22, paragraphs 1 and 4 of the GDPR, including profiling, and, if so, the logic applied and the significance and anticipated consequences of such processing for the data subject.
- In the contract and in the authorization, nothing is indicated regarding access or alternative use of the biometric registration, nor whether the communication of personal data is a legal or contractual requirement, or a necessary requirement to enter into a contract, and whether the data subject is obliged to provide personal data and is informed of the possible consequences of not providing such data;
- It does not refer to the withdrawal of consent, but rather to the revocation or opposition to it, considering that opposition to processing occurs when the legal basis for the data is Articles 6.1.e) and f) of the GDPR (Article 21 of the GDPR). Not mentioning revocation is technically acceptable, since the GDPR refers to the right to "withdraw consent, without affecting the lawfulness of the processing based on the consent before its withdrawal" (Article 13.2.c GDPR) or Article 7, paragraph 3), of the GDPR, which establishes that the data controller must ensure that the data subject can withdraw their consent at any time and that it will be as easy to withdraw it as it was to give it, referring more to an action than a right. Withdrawal of consent should not lead to any detriment or decrease the level of service provided.

Lack of information that does not appear to have changed throughout the relationship.

the user with the respondent, specifically at the moment when the fingerprint was to be collected effectively.

The submission in allegations regarding the modification of the information clauses in the contract or in the authorization does not prove the date on which they were implemented and does not cover all the aspects referred to that constitute the basic principle of transparency in the collection of the data being processed. The statement that it was displayed as informational signage is also not substantiated and still does not contain all the elements of information, with the respondent having provided information to different users on different dates.

Article 13 of the GDPR states that when personal data is collected from a data subject - which occurs through the contract and the "authorization" subject to the complaint - the data controller is obliged, at

that precise moment, that is, when the data is obtained, to inform the data subject, and in relation to the data that is going to be processed, not the data that will be processed in the medium or long term. These, if applicable, must be the subject of information when they are collected and processing begins.

It should be noted that the information regarding the data collection must correspond to what is actually collected and will be processed subsequently, and that is the reason why the data subject must be informed. Information provided in advance about data that will be collected or whose system is planned to be established in the future, in the medium term, 6 months, or in the long term, for example, one year, cannot suffice, as it does not comply with the principle of fairness and creates insecurity in processing, and such information should be considered as not provided since it does not align with the facts. In this case, information about data that will be collected in the future could lack effect, as the factual assumption regarding the object in question (collection and use of the fingerprint for access) is not met. It is noted that the information refers to a "biometric system" for access and the partial information associated with it, when, moreover, neither the data was collected (the fingerprint in this specific case for access, in May 2021) nor was it stored or used.

The subsequent processing that materializes when the data of the complainant was intended to be collected is when the information about such processing should have been completed, as this obligation, according to the Guidelines on transparency under the GDPR, issued by the Article 29 Working Party adopted on 29/11/2017, and revised on 11/04/2018, (point 5), is by no means static, but must be adapted to the cycles and processing operations and any modifications that may occur, especially if they entail a substantial change regarding the processing operation such as the collection and use of fingerprints for access to a facility, sports in this case.

The respondent, in its capacity as the data controller, in accordance with Article 13 of the GDPR was obliged to inform in the document through which they collect user data, including as stated in the article, the consequences of not providing it, at the moment when it is collected. Therefore, the fact that the complainant did not provide the fingerprint is not considered to exempt from providing such information, especially since she was already a user of the gym as in this case. Furthermore, it is expressly stated among this obligation, the effects that must arise in case of not providing the aforementioned data.

It is observed, therefore, and thus declared, that various aspects have been partially disregarded.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/50

fundamental information for the type of processing being carried out, considering that the aforementioned Article 13 of the GDPR has been violated by the respondent.

IV

As specific types, biometric data is defined in Article 4.14 of the GDPR:

“biometric data”: personal data obtained through a specific technical processing, related to the physical, physiological, or behavioral characteristics of a natural person that allow or confirm the unique identification of that person, such as facial images or fingerprint data;

To be considered biometric data in the sense of the GDPR, the processing of raw data, such as the physical, physiological, or behavioral characteristics of a natural person must involve a measurement of those characteristics. Thus, from the concept, it should not be overlooked:

- The nature of the data: data related to the physical, physiological, or behavioral characteristics of a natural person;
- The means and forms of processing: data “obtained through a specific technical processing”; which differentiates, for example, from images of a person that appear in a surveillance system, which cannot be considered biometric data unless they have been technically processed in a specific manner to contribute to the unique identification of that person. Recital 51 of the GDPR also refers to the systematic non-consideration of photographs as special category data processing, unless a specific technical processing means is applied that “allows the unique identification or authentication of a

natural person.”

- The purpose of the processing: the data must be used for the purpose of uniquely identifying a natural person.

Biometric data has the particularity of being produced by the body itself and definitively characterizes it; these are not data about that person, but rather the data refers to the same person, which in principle cannot be modified by the will of the individual, nor can the person be released from them; they cannot be changed in the event of compromise, loss, or intrusion into the system. Furthermore, because biometric data is unique to a person and perpetual, the user uses the same data across different systems. Therefore, identity theft is not only perpetual over time but also affects all systems in which a user has stored their biometric data. The holder, therefore, does not have the possibility to use one biometric data for the bank and a different one for their health system; rather, they use the same information to verify their identity in both, and in the event of a vulnerability, all of them are affected simultaneously.

All of this, without losing sight of the fact that it is a very intrusive identification system for the fundamental rights and freedoms of natural persons, among other circumstances due to the operation through artificial intelligence systems that im-

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/50

They implement algorithms to design and read the biometric template, in relation to the deficiencies in the manufacturing standards of approved and certified systems of the software in use, added to the extent and interoperability of the use of these systems. It is also important to highlight the restrictive nature of this note, as its processing is prohibited, as determined by Article 9.1 of the GDPR:

“Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and processing of genetic data, biometric data aimed at uniquely identifying a natural person, data concerning health, or data concerning a natural person's sex life or sexual orientation is prohibited.”

2. The provisions of paragraph 1 shall not apply where one of the following circumstances applies:

a) the data subject has given explicit consent to the processing of such personal data for one or more specified purposes, except where Union or Member State law provides that the prohibition referred to in paragraph 1 may not be lifted by the data subject;

Such data may only be processed exceptionally, in certain cases contemplated in the GDPR, which provides strict requirements to ultimately enable the operation of such systems, due to the impact on fundamental rights and freedoms, given the risks that the context of their processing may entail, and as noted in Recital 51 of the GDPR: “Such personal data should not be processed unless processing is permitted in specific situations provided for in this Regulation, taking into account that Member States may provide specific provisions on data protection in order to adapt the application of the rules of this Regulation to comply with a legal obligation or to perform a task carried out in the public interest or in the exercise of official authority vested in the data controller. In addition to the specific requirements for such processing, the general principles and other rules of this Regulation must apply, especially regarding the conditions for lawful processing. Explicit exceptions to the general prohibition on processing those special categories of personal data must be established, among other things when the data subject gives explicit consent or in relation to specific needs, particularly when the processing is carried out within the framework of legitimate activities by certain associations or foundations whose aim is to enable the exercise of fundamental freedoms.”

The definition of biometric data refers to “technical processing,” without specifying, except to note that the purpose of such processing must be to identify a person. Biometric characteristics undergo technical processing through a process that is contained in all biometric data processing: capture or recording of data, storage or processing, and the final phase of comparison.

C/ Jorge Juan, 6

The raw image of biometric characteristics is reduced, preserving highlighted discriminated information that is essential for the recognition of the person. These extracted characteristics are maintained in a biometric template, which is a reduced mathematical representation of the original characteristic. The reference template is stored for comparison. In the final phase, a biometric sample—such as the finger presented to the sensor—will be compared with a previously recorded template. The phases align with the enumeration of what could be a data processing operation (collection, storage, use).

On one hand, the definition of biometric data includes that through specific technical processing, they “allow or confirm” “the unique identification” of that person. The mentions of “allow” can be understood as identification, while “confirm” refers to verification. Therefore, both identification and authentication must be unique, pertaining to the identification that occurs of the person. Unique identification, on the other hand, goes beyond the data being of an identified or identifiable natural person. Data of an identified natural person means that this person is distinguished or isolated from a group of people. Unique may refer to the fact that biometric data has such particularities that can unambiguously identify an individual.

The differences between the terms identification and authentication refer to the method of searching in the stored records and the prior entry of the record, as inferred from Opinion 3/2012 of the GT 29, dated 27/04/2012, regarding the evolution of biometric technologies, at a time when biometric data did not enjoy the category of “special” that the GDPR introduces and therefore did not refer to the term “aimed at univocal identification.”

Recital 51 states that “The processing of photographs should not systematically be considered processing of special categories of personal data, as they are only included in the definition of biometric data when the fact of being processed by specific technical means allows for the univocal identification or authentication of a natural person. Such personal data should not be processed unless their processing is permitted in specific situations contemplated in this Regulation.”

Technically, the biometric template against which the sample is compared is the product of a measurement that uniquely and solely identifies the individual. This is what, for example, differentiates the images viewed from a video camera that cannot be considered biometric data under the definition of Article 9 unless they are specifically processed by a technical means to contribute to the identification of a person.

The biometric data of each user, acquired at the moment of capture and recorded, are subjected to the technical procedure that converts the image, the format, into a biometric sample and the algorithm into a biometric template, being stored, so that, with the samples introduced by placing the finger on the access points, it identifies through the saved model, among all the templates, without a doubt, its holder, which would be uniquely for that person.

The use of the fingerprint is not only capable of validating identity accurately but also contains unique information about natural persons. The software algorithm, on the biometric sample, extracts the biometric characteristics, reduces and transforms them into a biometric template.

label or numbers that sample, constituting a mathematical representation of the original biometric characteristic, which is the biometric template. The template is stored for comparison in the final phase in which, with the biometric sample-fingerprint on the reader-and with the previously recorded template, it uniquely identifies the employee each time they enter or exit by placing their fingerprint on the reader, which is why it is considered that the data falls within the scope of special data.

In this case, of course, it cannot be said that it is not information linked to personal data of an identified person in each access record, even though the data is stored on the device encrypted. Each time a

user utilizes the system, they allow or confirm their unique identification through the processing carried out by the defendant with the acquired device. The presented sample is compared, and the system has the function of identification with a biometric function, uniquely identifying the user who claims to be and recording their data, as it should be noted that if it did not allow for the unequivocal identification of the user, free access of the member to the facility would not occur.

V

Having established that these are special category data, to process special categories of data, coverage must be found in Article 9.2 of the GDPR, and once the general prohibition is excepted, one must refer to the provisions of Article 6.1 of the GDPR to legitimize the processing in question. The data controllers may only process special category personal data if one of the conditions set out in Article 9, paragraph 2, is met, as well as a condition from Article 6, so it is appropriate to reproduce the provision:

“1. Processing shall be lawful only if at least one of the following applies:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is party or to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) processing is necessary to protect the vital interests of the data subject or of another natural person;
- e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/50

by the data controller or by a third party, provided that the interests of the data subject do not prevail over the interests or fundamental rights and freedoms that require the protection of personal data, particularly when the data subject is a child.

The provisions in letter f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions.

There is no reference as a legal basis for the processing of the biometric register for access to the gym of the respondent related to the consent in the information on the processing provided to the complainant.

Moreover, even if there were such consent, as should be anticipated, the option not to grant it without any negative consequences is not considered an adequate legal basis for processing data in that manner with the provision of this service, unless a real and effective alternative to the use of the fingerprint is provided. In this case, it is also not proven that the use of the fingerprint was or is necessary for the provision of the service (the complainant did not use it from 2/09/2020, proving its unnecessary nature).

Regarding the respondent's claim that submitting to the capture of the fingerprint implies consent to the processing, it must be understood that given the specificity of consent, and the information that must be associated with it, as well as the voluntary option not to submit to it without suffering negative repercussions, it does not constitute per se an adequate legal basis for legitimizing the processing, unless both the information on its use and a free alternative not to use it for those who do not wish to grant such explicit consent for it being a special biometric data are properly developed.

Usually, this legal basis for processing must be preceded by an adequate analysis of the necessity and proportionality of the circumstances of the implementation and use of the fingerprint, the alternatives to its use, and the impact on the rights of its holders, risks, guarantees, and the security measures that come with the development of technology.

The establishment of consent as a legal basis for processing, in the use of the fingerprint, may affect

the provision of a service that is contracted, conditioning it on the acceptance of those modalities of processing, due to the legal position of the controller.

LLEFISA also states in its RAT that the legal basis for processing is consent and the commercial contract. Given that such consent is not established, the contractual relationship must be analyzed as a legitimization for the registration of fingerprints to access the facilities, which would fall under Article 6.1.b of the GDPR, as: "the processing is necessary for the performance of a contract in which the data subject is a party or for the implementation at the request of the data subject of pre-contractual measures;"

Relating the purposes that the respondent intended with the use of the fingerprint:

- management of the personal data of subscribers to allow them access to the facility. (RAT).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/50

- that the system recognizes the interested party and allows access to the gym through this identification. (EIPD).

- to protect the safety of individuals accessing the center and their belongings, as well as the facilities themselves (contract and authorization), necessary service conditions for the proper functioning of the center and access control for members only.

In any case, it is not necessary for the execution of the contract to register fingerprints for access when there may be other means to access, as evidenced by the claimant who was using the facilities since their registration, a time when the fingerprint system was not established.

On the other hand, the respondent also does not demonstrate in the EIPD the necessity and proportionality of establishing the fingerprint for such purposes.

Thus, it is noted that the initial infringement of Article 7.4 of the GDPR—conditions for consent—attributed to LLEFISA should be modified.

The provision that ties the consent of the interested party to the processing does not apply, as the basis for consent is not established, not only because there is no mention of the elements specific to this figure to decide on it, nor is it even referred to, nor is it mentioned as a legal basis for processing, for informational purposes. Furthermore, as has been emphasized, it may not be a legal basis for legitimization for the processing of fingerprints in the provision of a service without an alternative to its non-use. This implies that the attribution of the aforementioned article should be changed.

Apart from consent as a legal basis for processing, the rest contemplated in Article 6.1 of the GDPR all imply the "necessity" of processing, a term that is expressly contained. In this sense, the European Data Protection Board (formerly the Article 29 Working Party) in its opinion on "Guidelines on Automated Individual Decision-Making and Profiling for the purposes of Regulation 2016/679" indicates that to process special categories of data, coverage must be found in Article 9.2 GDPR, and once the general prohibition is excepted, one must refer to the provisions of Article 6 GDPR to legitimize the processing in question. (...) Data controllers may only process special category personal data if one of the conditions set out in Article 9, paragraph 2, is met, as well as a condition from Article 6. (...).

Regarding the allegation that it is proven that users only have the means of using fingerprints and wristbands for access to the gym, it is indicated that this is not reflected in the proven facts.

Considering that data included in Article 9.1 is present, with the exceptions for processing provided in 9.2 of the GDPR, which are not demonstrated to be present in the respondent, and that, furthermore, a legitimizing basis within Article 6.1 of the GDPR is required, the one alleged for the case, that of Article 6.1.b) of the GDPR, is not valid, it is considered that LLEFISA has infringed the following two articles:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/50

- Article 9.1 of the GDPR, and
- Article 6.1 of the GDPR.

VI

The corrective powers of the Spanish Data Protection Agency, as the supervisory authority, are established in Article 58.2 of the GDPR. Among them is the power to impose an administrative fine in accordance with Article 83 of the GDPR -Article 58.2 i)-.

In this case, considering the facts presented, it is deemed that the sanctions that should be imposed are administrative fines due to the provision of a paid service, which in this case affects consumers and a number, if not massive, certainly high, in this case more than a thousand potential users responding to an offer of such services and given the strict requirements for the processing of this type of data, with information about the processing being an essential content of the right within data processing and due to the type and specificity of the fingerprint data whose prohibited processing meets various requirements in cases where its use is necessary.

In response to the respondent's allegation that it discriminates, for example, with the public sector, it should be noted that in these cases an economic sanction would not proceed as expressly indicated by Article 77 of the LOPDGDD, which may lead to the adoption of other measures indicated in its point 3.

VII

The infringements attributed to the respondent are classified in Article 83.5 of the GDPR, which considers that the infringement of

- "a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9" and

- "b) the rights of the data subjects under Articles 12 to 22;

which," are sanctionable, according to paragraph 5 of the aforementioned Article 83 of the cited Regulation, "with administrative fines of up to €20,000,000 or, in the case of a company, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount."

The LOPDGDD in its Article 72.1 considers, for the purposes of prescription, that they are:

"Very serious infringements and will prescribe after three years the infringements that imply a substantial violation of the articles mentioned therein and, in particular, the following:

"b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/50

"e) The processing of personal data of the categories referred to in Article 9 of Regulation (EU) 2016/679, without any of the circumstances provided for in that provision and in Article 9 of this organic law occurring."

Also within the LOPDGDD, Article 74 considers "minor and will prescribe after one year the remaining purely formal infringements of the articles mentioned in paragraphs 4 and 5 of Article 83 of Regulation (EU) 2016/679 and, in particular, the following:

(...)

"a) The failure to comply with the principle of transparency of information or the right to information of the affected party by not providing all the information required by Articles 13 and 14 of Regulation (EU) 2016/679."

VIII

The fines imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with Article 83.1 of the GDPR. In order to determine the administrative fine to be imposed, the provisions of Article 83.2 of the GDPR must be observed, which states:

“2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42,
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, “Sanctions and corrective measures,” provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party could have included the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

Regarding the allegation that the aggravating factors would constitute a double computation of factors, given that the infringement is already very serious, it should be noted that Article 83.2 of the GDPR already provides that both for the imposition of the sanction and...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/50

For its amount, the circumstances that concur in the assessed facts must be taken into account.

On the other hand, this joint and systematic assessment may result in a conclusion drawn from various

elements regarding an increase or decrease in the unlawfulness or culpability that must concur in the facts, which means that the claim made by the defendant cannot be upheld.

For the infringement of Article 13 of the GDPR, a fine of €2000 (two thousand euros) is imposed.

For the infringement of Article 9.1 of the GDPR, in order to determine the amount of the sanction to be imposed in this case, it is considered appropriate to adjust the sanction according to the following circumstances included in Article 83.2 of the GDPR:

As aggravating circumstances:

- Article 83.2.g) regarding "the categories of personal data affected by the infringement."

The RAE dictionary defines the term "category" as "each of the classes or divisions established when classifying something." The reading of Article 83.2.g) of the GDPR initially refers us—through a literal and strict interpretation of the norm—to the heading of Article 9 of the GDPR, "Processing of special categories of personal data," thus concluding that the GDPR classifies personal data solely into specially protected and the rest.

However, a systematic and teleological interpretation of Article 83.2.g) of the GDPR connects this provision with other classifications offered by the text of the GDPR that, moreover, better respond to the purpose pursued by the norm: to adjust in the individual case the administrative fine that must be imposed while respecting the principles of proportionality and effectiveness.

In this sense, recitals 51 and 75 of the GDPR distinguish a group of personal data that, by their nature, are particularly sensitive due to the significant risk they may entail, in the context of their processing, for fundamental rights and freedoms. The common denominator of all of them is that their processing involves a significant risk to fundamental rights and freedoms as it may lead to physical, material, or immaterial harm. This group or category of particularly sensitive data includes the categories of specially protected data regulated by Article 9 of the GDPR (recital 51 of the GDPR) and, additionally, many other data not regulated in that provision. Recital 75 details the personal data whose processing may entail a risk, of varying severity and probability, for the rights and freedoms of individuals as a consequence of potentially causing physical, material, or immaterial harm. Among them, it mentions those whose processing "may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/50

In the present case, it is considered that the fact that the consent for the processing of the claimant's data obtained by the defendant pertained to a particularly sensitive data, fingerprint, impacts the severity of the conduct, and the concurrence of the circumstance in the capacity of an aggravating factor must be appreciated in accordance with paragraph g) of Article 83.2 of the GDPR.

- Circumstance of Article 83.2.k) GDPR in relation to Article 76.2.b) LOPDGDD:

The link between the business activity of the defendant and the processing of personal data.

The defendant, in the development of its own activity, needs to routinely process personal data, and this fact affects the diligence that is required in complying with the principles governing the processing of personal data and the quality and effectiveness of the technical and organizational measures that must be implemented to ensure respect for this fundamental right of both its clients and third parties. Regarding the defendant's allegation that there is no such link between its sports business activity and the processing of personal data, and that its activity consists of providing clients with machines, equipment, and trainers, for which it does not need to process, nor does it routinely process personal data, the facts are that it is a lucrative activity that provides a variety of services and requires data for its ordinary management, using various technologies that link user data for its management, both at the level of technologies: bracelet, fingerprint, as well as affecting its internal implementation of management software, data processing contract, to give just one example.

- From Article 83.2.a) "the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected

parties and the level of damages and losses they have suffered.”

The number of affected persons, therefore, although there is only one claimant, it is evident that all clients of the entity have been affected.

From Article 83.2.b) “the intentionality or negligence in the infringement.” In fulfilling its legal obligations - as far as the principle of obtaining consent for lawful data processing is concerned - the defendant must act with the diligence that the circumstances of the case require. Regarding the degree of diligence that the data controller is obliged to exercise, the ruling of the National Court, Administrative Litigation Chamber, of October 17, 2007 (rec. 63/2006), which, although issued under the previous regulation, is extrapolatable to the matter at hand. The National Court, after indicating that entities whose activities involve continuous processing of data from clients and third parties must observe an adequate level of diligence, specifies that “...the Supreme Court has understood that there is imprudence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

46/50

that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be emphasized the rigor and the utmost care required to comply with the legal provisions in this regard.” (The underlining is from the AEPD).

In this case, the lack of diligence of the defendant must be classified as “serious.” The entity should have been particularly scrupulous in verifying the obtaining of any exception for the processing of the initially prohibited data, which the “feasibility” study conducted by the DPD stated was necessary for its processing to have a double authorization.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions established in Article 9.1 of the GDPR, leads to the imposition of a fine of 15,000 euros.

Regarding the infringement of Article 6.1 of the GDPR, the following circumstances must be considered for the grading of the infringement:

- From Article 83.2.a) “the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered.” Neither the contractual relationship can contribute to a necessary implementation of a processing system outside of a thorough analysis of necessity and proportionality, nor the supposed consent, given the nature of the processing and from the date it was implemented, May 2021, which affects all users, aggravating elements are estimated. Based on this context, the imposed infringement is 10,000 euros.

Regarding the absence of culpability due to having analyzed the risks and not having violated the security measures, these elements are not assessed in this procedure, and culpability as the capacity of the obligated subject to act differently and, therefore, in accordance with the legal system, is clear that it concurs, recalling that the Supreme Court (Judgments of 16 and 22/04/1991) considers that from the element of culpability it is inferred “that the action or omission, qualified as an administratively sanctionable infringement, must be, in any case, attributable to its author, either by intent or negligence, imprudence, or inexcusable ignorance.”

Regarding the allegation of the economic situation of the defendant, after analyzing the figures, it is estimated that the amounts of the three fines are unlikely to compromise its economic structure or future, given the revenue figures, considering the points from which Article 83.5 of the GDPR starts, and they can be considered proportional and deterrent for the violation of the examined provisions that have been infringed upon more than a thousand users of their services.

Regarding the existence of a DPD as a mitigating factor, the provision states that it “may be taken into account,” which means it cannot be accepted automatically. In this case, the commission of the infringements, which are not episodic but structural, their permanence has not served for the contrary,

without having analyzed their role in the treatments.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/50

Regarding the fact that no evidence has been presented and this should serve as a mitigating factor, it must be indicated that it does not specify which fact was to be practiced, or what the fact would have been had it been requested, being certain that it was not proposed in the allegations to the initiation agreement. On the other hand, as stated in Article 77 of the LPCAP, it is not a mandatory procedure, considering that there was no disagreement regarding the facts within the framework of the sanctioning procedure.

Finally, concerning the assertion that the declared infringements would not affect all partners, it is noted in this case that the action of submitting to the collection of the fingerprint per se does not meet the requirements of consent, nor is it considered explicit with respect to data protection regulations; thus, the mentioned impact on everyone is not incorrect, as is the informative clause.

IX

Article 58.2 of the GDPR provides as follows: “Each supervisory authority shall have all of the following corrective powers:

d) to order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame;”

f) to impose a temporary or definitive limitation on processing, including a prohibition; [...]”

i) to impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this section, depending on the circumstances of each particular case;”

“The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.”

It is not evidenced that the respondent has ceased to use the fingerprint as a means of access to the sports facility using a modality that incurs the same absence of a legitimizing basis and authorization for the prohibited processing of the fingerprint that has been indicated in this resolution for the entire group from which the fingerprint data has been collected based on the same clause. The measures for readjusting the processing have not been evidenced to have taken place effectively during the processing of the file for all the data subjects from whom their data was collected at that time and under such premises, one of the most important being the express reflection of an alternative measure to the use of fingerprinting as it is known to have been available.

It is therefore considered that, in order to guarantee the rights and freedoms of the data subjects, there is a need and justification for adopting the corrective powers determined in the dispositive part.

Article 90.3 of the LPCAP states that “the resolution that concludes the procedure shall be enforceable when no ordinary administrative appeal can be lodged against it, and precautionary measures may be adopted therein to ensure its effectiveness until it becomes enforceable.”

The text of the resolution establishes what the facts are that determine the need for compliance with data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

You are informed that, according to Article 83.6 of the GDPR, non-compliance with the resolutions of the supervisory authority adopted in accordance with Article 58.2 of the GDPR constitutes an

autonomous infringement in itself, which will lead to the opening of the corresponding sanctioning file for such infringement, for which a fine of up to 20,000,000 euros is foreseen as a maximum or, in the case of a company, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount.

Therefore, in accordance with the applicable legislation and assessed the criteria for the graduation of the sanctions whose existence has been evidenced, the Director of the Spanish Data Protection Agency RESOLVES:

FIRST: TO IMPOSE on LLEFISA, S.L with NIF B60422417 for the following infringements of the GDPR:

- Article 13 of the GDPR, in accordance with Article 83.5.b) of the GDPR, classified for prescription purposes in the article of the LOPDGDD, an administrative fine of 2,000 euros.
- Article 9.1 of the GDPR, in accordance with Article 83.5.a) of the GDPR, classified for prescription purposes in Article 72.1.e) of the LOPDGDD, an administrative fine of 15,000 euros.
- Article 6.1 of the GDPR, in accordance with Article 83.5.a) of the GDPR, classified for prescription purposes in Article 72.1.b) of the LOPDGDD, an administrative fine of 10,000 euros.

SECOND: To require LLEFISA S.L, in application of Articles 90.3 of the LPCAP, and 58.2.d) and f) of the GDPR, to:

- Provide evidence within 30 days of a correct and adequate implementation of the fingerprint usage system for access to facilities, considering and evidencing its necessity and proportionality in relation to the establishment of a lawful basis for the processing of the data, also regarding those for whom that data is already available, and its corresponding information on the processing associated with it.

49/50

- Proceed to: "temporarily or definitively limit the processing" within ten days regarding the use of the gym access system with fingerprint, as long as it does not adjust the legitimizing basis of the processing and its correct information to the users. After the granted time has elapsed, you must inform this AEPD.

Failure to comply with the requirement may result in the commission of an infringement of Article 83.6 of the GDPR.

THIRD: NOTIFY this resolution to LLEFISA, S.L.

FOURTH: Warn the sanctioned party that they must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of the LPACAP, within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of 29/07, in relation to Article 62 of Law 58/2003, of 17/12, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN:

ES00-0000-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receiving the notification and once it is enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second month following or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of 13/07, regulating the Contentious-Administrative Jurisdiction, within two months from

the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the cited Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/50